CADERNO DE MICROTAREFAS PRÁTICAS

Segurança em Cloud: Redes e Perímetro

Nome do Aluno: _____ **Data:** ____/____/_____

Turma: _____ **Nota / Avaliação:** _____

Microtarefa 1: Isolamento de Banco de Dados e Arquitetura em 3 Camadas

Cenário: A TechNova está migrando uma aplicação legada para a nuvem. Um analista atribuiu um IP público com a porta 3306 (MySQL) aberta para 0.0.0.0/0 ao banco de dados corporativo para facilitar acessos remotos da equipe.

Questão: Com base na arquitetura de referência de 3 camadas (Entrada, Aplicação e Dados), explique a falha cometida e descreva a estrutura correta para isolar o banco de dados.

Espaço para Resposta / Justificativa Técnica:

Microtarefa 2: Security Group (Stateful) vs. Network ACL (Stateless)

Cenário: Um administrador liberou a porta 443 (HTTPS) de entrada em uma Network ACL (NACL), mas a aplicação continuou inacessível. Ao criar a mesma regra em um Security Group (SG), a conexão funcionou imediatamente sem precisar de regras de saída.

Questão: Explique por que o Security Group funcionou sem regra explícita de saída, enquanto a Network ACL exigiu configurações adicionais nas portas efêmeras de retorno.

Espaço para Resposta / Justificativa Técnica:

Microtarefa 3: Proteção na Borda com WAF vs. Patching de Aplicação

Cenário: Um portal web sofreu tentativas de SQL Injection e XSS. A equipe implantou um WAF na CDN de borda. Um desenvolvedor afirmou que, com o WAF ativo, a equipe não precisa mais corrigir as vulnerabilidades no código-fonte.

Questão: Avalie a afirmação do desenvolvedor. Qual é a função real do WAF e por que ele não substitui a sanitização de código e aplicação de patches?

Espaço para Resposta / Justificativa Técnica:

Microtarefa 4: Acesso Administrativo Temporário e Riscos do 0.0.0.0/0

Cenário: Durante um plantão de manutenção, um analista liberou a porta SSH (22) no Security Group para a origem 0.0.0.0/0 e esqueceu a regra aberta durante todo o final de semana.

Questão: Quais são os riscos imediatos dessa exposição? Descreva duas alternativas seguras de acesso remoto administrativo sem expor a porta 22 diretamente à internet pública.

Espaço para Resposta / Justificativa Técnica:

Microtarefa 5: Monitoramento de Egress e Prevenção contra Exfiltração

Cenário: A equipe de SOC identificou uma instância privada transferindo volumosas quantidades de dados para um IP desconhecido no exterior através da porta 443/TCP.

Questão: Explique o conceito de tráfego de saída (Egress) e como regras restritivas e o monitoramento de VPC Flow Logs auxiliam na detecção e contenção de exfiltrações.

Espaço para Resposta / Justificativa Técnica:

Microtarefa 6: Microssegmentação e Prevenção de Movimentação Lateral

Cenário: Um atacante explorou uma falha de RCE em um servidor web público e, a partir dele, conseguiu acessar diretamente a API de pagamento e a base de dados interna da empresa.

Questão: O que faltou na arquitetura de rede para impedir essa movimentação lateral? Como aplicar a microssegmentação de rede para isolar as camadas?

Espaço para Resposta / Justificativa Técnica:

Microtarefa 7: Estratégia Anti-DDoS e Absorção de Pico na Borda

Cenário: Durante um evento promocional, o e-commerce sofreu simultaneamente um ataque SYN Flood (L3/L4) e um HTTP Flood (L7), sobrecarregando os servidores da aplicação.

Questão: Quais mecanismos de borda e arquitetura de nuvem devem ser combinados para absorver e mitigar esses dois tipos de ataques DDoS?

Espaço para Resposta / Justificativa Técnica:

Microtarefa 8: Conectividade Híbrida e Endpoints Privados (VPC Endpoints)

Cenário: Uma equipe planeja atribuir um IP público a um banco de dados gerenciado em nuvem para permitir que sistemas locais (on-premises) realizem consultas diárias.

Questão: Por que atribuir IP público ao banco é uma má prática? Qual é a solução recomendada utilizando conexões privadas (VPN/Direct Connect) e VPC Endpoints?

Espaço para Resposta / Justificativa Técnica:

Microtarefa 9: Zero Trust Network Access (ZTNA) vs. VPN Tradicional

Cenário: Ao conectar via VPN tradicional, um usuário remoto ganha acesso IP direto e irrestrito a toda a faixa de sub-redes corporativas (10.0.0.0/16).

Questão: Por que essa abordagem de VPN tradicional viola o modelo Zero Trust? Como o ZTNA aprimora a segurança do acesso remoto?

Espaço para Resposta / Justificativa Técnica:

Microtarefa 10: Auditoria de Regras de Firewall e Mapeamento de Mudanças

Cenário: Uma auditoria de segurança descobriu 15 regras obsoletas em Security Groups liberando portas para IPs de ex-fornecedores e testes já desativados.

Questão: Quais práticas de governança, automação e Infraestrutura como Código (IaC) devem ser adotadas para evitar a degradação e o acúmulo de regras de firewall obsoletas?

Espaço para Resposta / Justificativa Técnica: